

*CACS402: Cloud
computing
BCA 7th Semester*

Unit-5: cloud security

Mechi Multiple Campus
Bhadrapur



Cloud Security

- » Introduction to Security,
- » Cloud Security challenges and Risks,
- » Software-as-a-Service Security
- » Security Monitoring
- » Security Architecture Design
- » Data Security
- » Application Security
- » Virtual Machine Security
- » Identity Management and Access Control

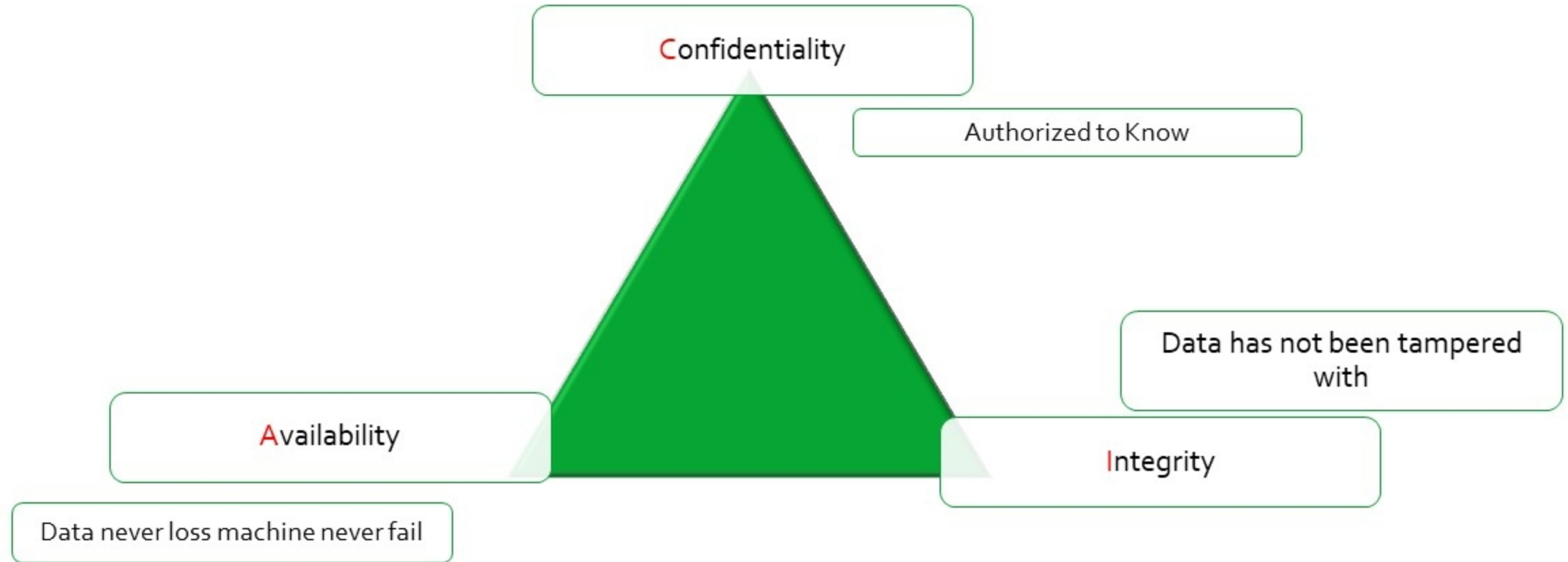
Definition of cloud security

- » Cloud security, also known as **cloud computing security**, is a **collection of security** measures designed to **protect cloud-based infrastructure, applications, and data**. These measures **ensure user and device authentication, data and resource access control, and data privacy protection**. They also support **regulatory data compliance**. Cloud security is employed in cloud environments to protect a **company's data** from **distributed denial of service (DDoS) attacks, malware, hackers, and unauthorized user access** or use.

Cloud Computing Security

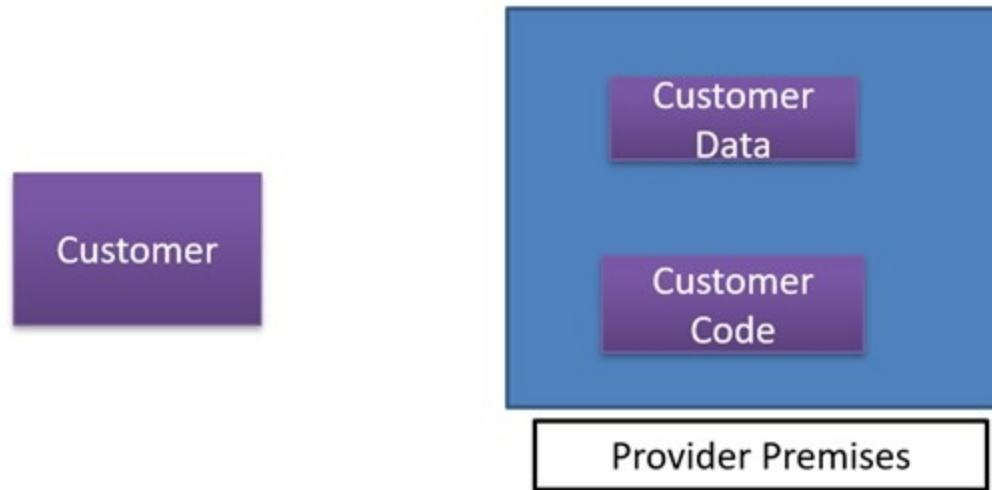
- » Security in cloud computing is a major concern.
- » Data in cloud should be **stored in encrypted form**.
- » To restrict client from accessing the shared data directly, **proxy and brokerage services** should be employed.

Security Services



Cloud Security !! A major Concern

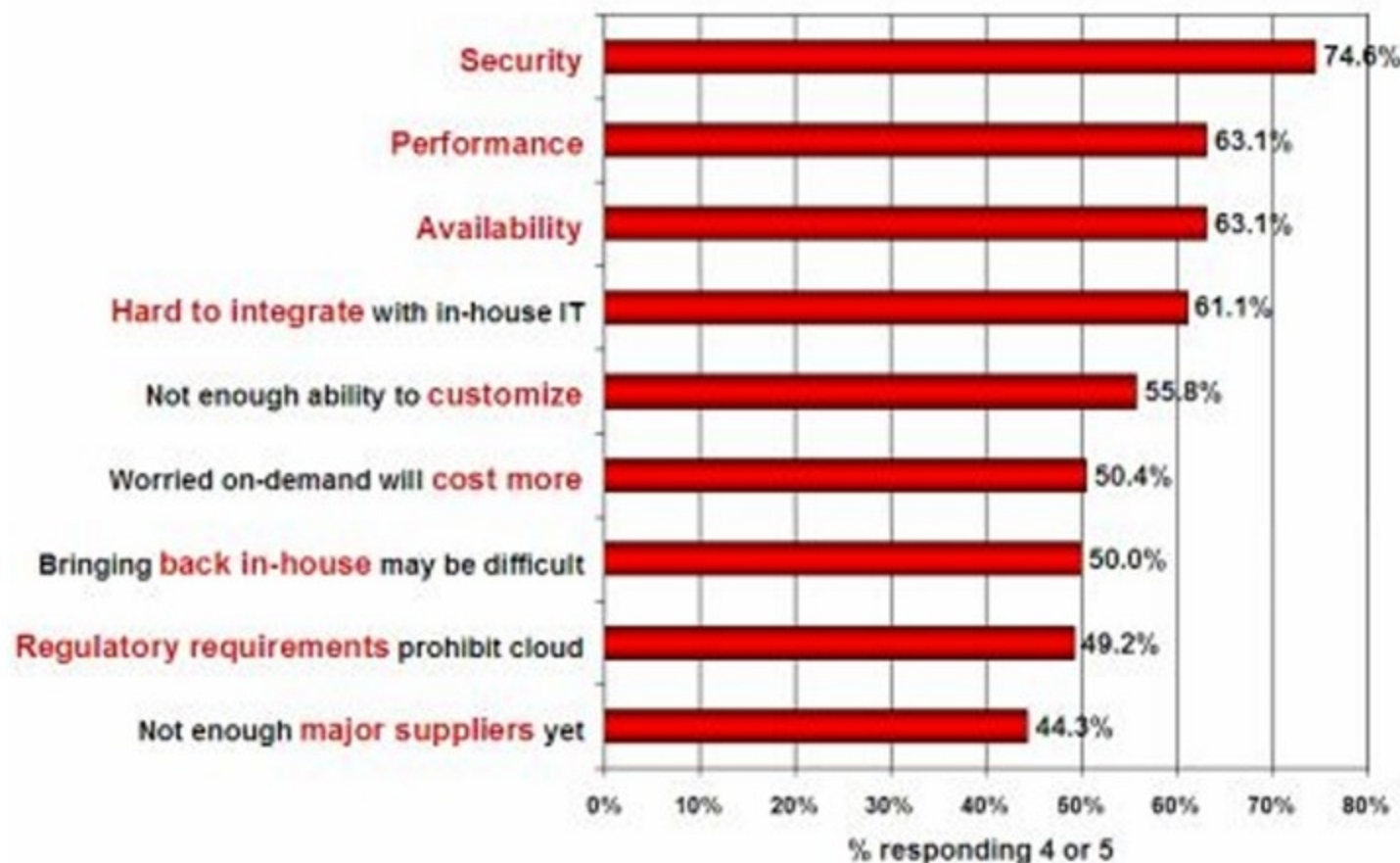
- » Security concerns arising because both **customer data and program** are residing at **Provider Premises**.
- » Security is always a major concern in **Open System Architectures**



Security Is the Major Challenge

Q: Rate the **challenges/issues** ascribed to the 'cloud'/on-demand model

(1=not significant, 5=very significant)



Source: IDC Enterprise Panel, August 2008 n=244

Cloud Security

- » Cloud Security Alliance (CSA) stack model defines the **boundaries between each service model** and shows **how different functional units relate to each other**.

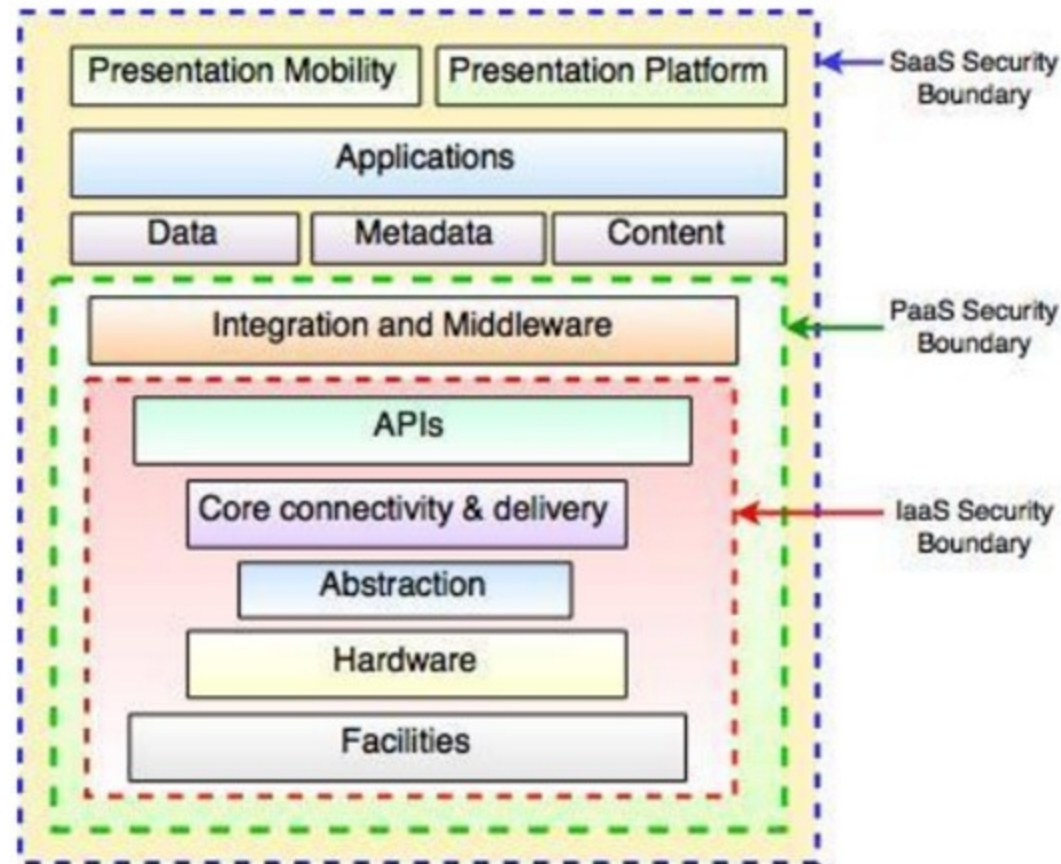


Fig - CSA Stack Model

Cloud Security

- » Data protection is a crucial security issue for most organizations.
- » Before moving into the cloud, cloud users need to clearly identify data objects to be protected and classify data based on their implication on security, and then define the security policy for data protection as well as the policy enforcement mechanisms.
- » For most applications, data objects would include not only bulky data at rest in cloud servers (e.g., user database and/or file system), but also data in transit between the cloud and the user which could be transmitted over the Internet or via mobile media.
- » Data objects may also include user identity information created by the user management model, service audit data produced by the auditing model, service profile information used to describe the service instances, temporary runtime data generated by the instances, and many other application data.

Cloud Security

- » IaaS is the most basic level of service with PaaS and SaaS next two above levels of services.
- » Moving upwards, each of the service inherits capabilities and security concerns of the model beneath.
- » IaaS provides the infrastructure, PaaS provides platform development environment, and SaaS provides operating environment.
- » IaaS has the least level of integrated functionalities and integrated security while SaaS has the most.
- » This model describes the security boundaries at which cloud service provider's responsibilities end and the customer's responsibilities begin.
- » Any security mechanism below the security boundary must be built into the system and should be maintained by the customer.

Threats and Challenges to Cloud Computing

- 1 . Abuse and nefarious(dishonest) use of cloud computing
2. Insecure application programming interfaces
3. Malicious insiders
4. Shared technology vulnerabilities
5. Data loss/leakage
6. Account, service, and traffic hijacking
7. Unknown risk profile

Abuse and Nefarious Use

- » Password and key cracking
- » DDOS (Distributed Denial of services)
- » Launching dynamic attack points
- » Hosting malicious data
- » Botnet command and control
- » Building rainbow tables(a large precomputed table designed to cache the output of the cryptographic hash functions to decrypt hashed passwords)
- » CAPTCHA solving

Insecure Interfaces and APIs

- » Could expose more functionality than intended.
- » Policy could be circumvented (avoided).
- » Credentials may need to be passed –is the interface secure?

Malicious Insiders

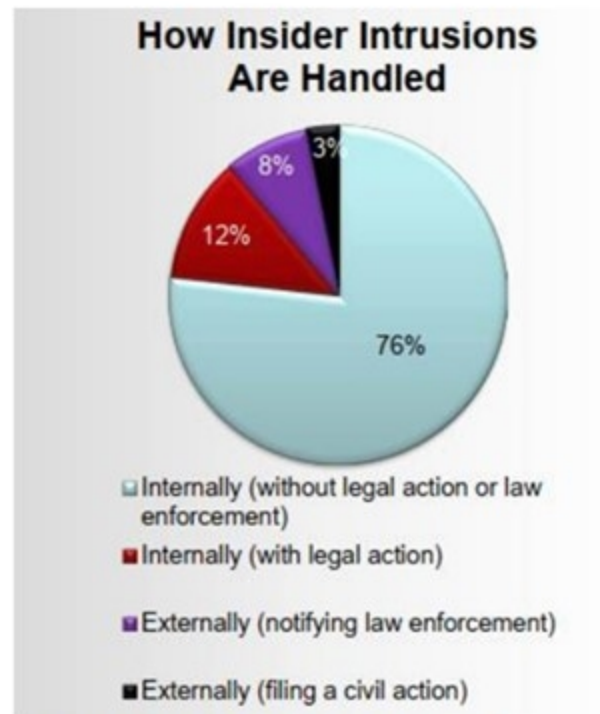
- » These are the current or former employees, contractors, or other business partners who :
 - have or had authorized access to an organization's network, system or data and
 - intentionally exceeded or misused that access in a manner that negatively affected the confidentiality, integrity, or availability of the organization's information or information systems
- » Little risk of detection
- » System administrator qualifications and vetting (validation) process for cloud services provider may be different that that of the data owner.

Malicious Insiders

Malicious Insiders



CERT's Insider Threat Case Database



Source: 2011 CyberSecurity Watch Survey, CSO Magazine, U.S. Secret Service, Software Engineering Institute CERT Program at Carnegie Mellon University and Deloitte January 2011

Shared Technology Issues

- » Underlying architecture (CPU cache, GPU, etc.) not intended to offer strong isolation properties
- » Virtualization hypervisor used to mediate access between guest OS and physical resources
- » Exploits exist (Blue Pill, Red Pill)
- » Blue Pill: a malicious thin hypervisor-based rootkit that takes controls of the victim machine,
- » Red Pill: a forensic software that runs on the inspected machine and detects the existence of malicious hypervisor or blue pil.

Data Loss or Leakage

- » Data is outside the owner's control
- » Data can be deleted or decoupled (lost)
- » Encryption keys can be lost
- » Unauthorized parties may gain access
- » Caused by
 - Insufficient authentication, authorization, and access controls
 - Persistence and remanence
 - Poor disposal procedures
 - Poor data center reliability

Account or Service Hijacking

- » Exploits phishing attacks, fraud, or software vulnerabilities
- » Credential reuse

Unknown Risk Profile

- » How well is the cloud being maintained?

Many companies are unwilling to release details

- » Is the infrastructure up to date?
 - Patches
 - Firmware
- » Does the combination of different service providers create previously unseen vulnerabilities?

Data Security Services

- » The basic security services for information security include assurance of data Confidentiality, Integrity, and Availability (CIA triad).
- » In Cloud Computing, the issue of data security becomes more complicated because of the intrinsic cloud characteristics.

1. Data confidentiality assurance

- This service protects data from being disclosed to illegitimate parties.
- In Cloud Computing, data confidentiality is a basic security service to be in place.
- Although different applications may have different requirements in terms of what kind of data need confidentiality protection, this security service could be applicable to all the data objects discussed above

Data Security Services

2. Data integrity protection

- » This service protects data from malicious modification.
- » When having outsource their data to remote cloud servers, cloud users must have a way to check whether or not their data at rest or in transit are intact. Such a security service would be of the core value to cloud users.
- » When auditing cloud services, it is also critical to guarantee that all the audit data are authentic since these data would be of legal concerns.

3. Guarantee of data availability

- » This service assures that data stored in the cloud are available on each user retrieval request. This service is particularly important for data at rest in cloud servers and related to the fulfillment of Service Level Agreement(SLA).
- » For long-term data storage services, data availability assurance is of more importance because of the increasing possibility of data damage or loss over the time

Data Security Services

4. Secure data access

- This security service is to limit the disclosure of data content to authorized users.
- In practical applications, disclosing application data to unauthorized users may threaten the cloud user's business goal.
- In mission critical applications, inappropriate disclosure of sensitive data can have juristic concerns.
- For better protection on sensitive data, cloud users may need fine grained data access control in the sense that different users may have access to different set of data.
- This security service is applicable to most of the data objects addressed above

Data Security Services

5. Regulations and compliances

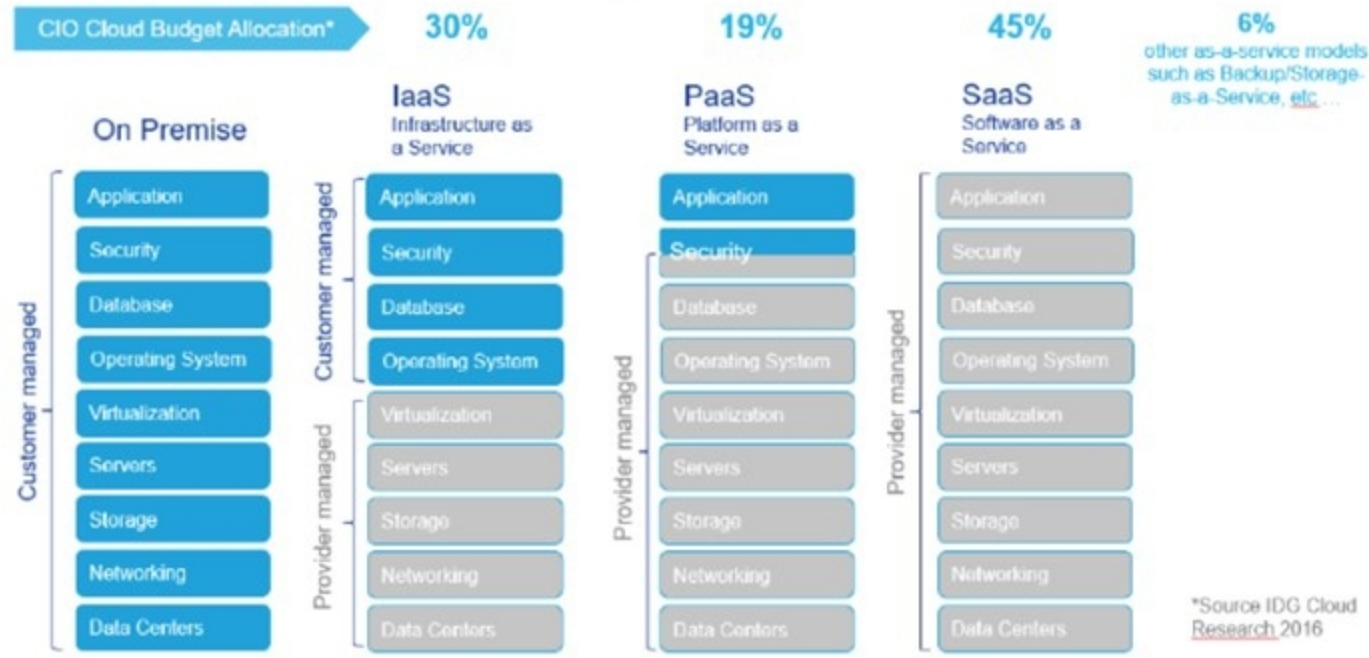
- In practical application scenarios, storage and access of sensitive data may have to comply specific compliance.
- For example, disclosure of health records may be limited by the Health Insurance Portability and Accountability Act (HIPAA).
- In addition to this, the geographic location of data would frequently be of concern due to export-law violation issues.
- Cloud users should thoroughly review these regulation and compliance issues before moving their data into the cloud

6. Service audition

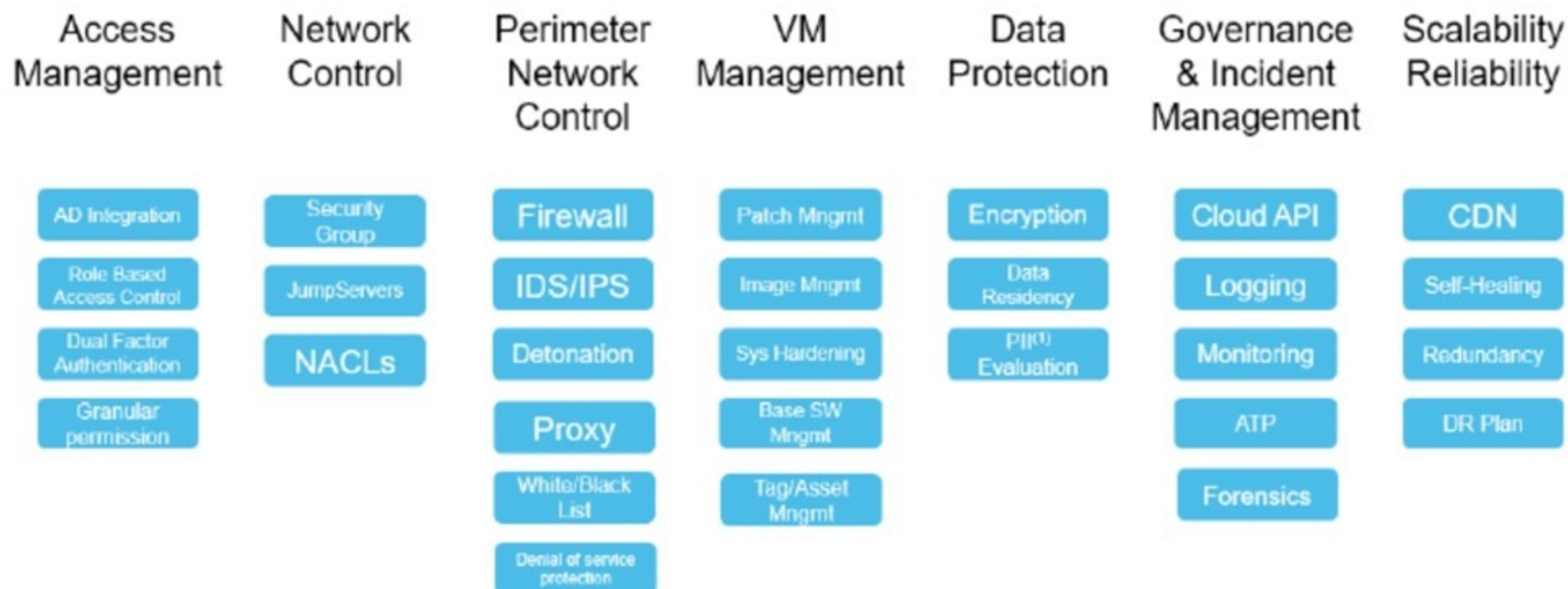
- This service provides a way for cloud users to monitor how their data are accessed and is critical for compliance enforcement.
- In the case of local storage, it is not hard to audit the system.
- But in Cloud Computing, it requires the service provider to support trustworthy transparency of data access.

SaaS Security

- » SaaS security refers to the **practices and policies implemented by the providers of the Software-as-a-Service to ensure the privacy and security of the customer data** in cloud based applications and other information assets.



Seven pillars of SaaS security



Seven Pillars Of SaaS Security

Seven pillars of SaaS security

1. Access Management

- » Who can access your cloud deployment and what permissions do they have?
- » The vendor must provide a unified framework to manage user authentication through business rules that determine appropriate user access based on organizational role, the system accessed, the data requirements, and workflow assignments, independently of the device used.

2. Network Control

- » Security groups control who can access specific instances across the network.
- » For more granular control, this can also include jump servers and network access control lists (NACL).
- » An optional layer of security for a virtual private cloud, acting as a firewall for controlling traffic in and out of one or more subnets

3. Perimeter Network Control

- » Perimeter defense has traditionally been about controlling traffic flowing into and out of a data center network.
- » The primary technology that underpins perimeter protection is a firewall, which filters out potentially dangerous or unknown based on a set of rules about the types of traffic and permitted source/destination addresses on the network.
- » Most organizations also deploy further levels of perimeter protection such as intrusion detection and prevention systems (IDS/IPS), which look for suspicious traffic after it has passed through the firewall.

Seven pillars of SaaS security

4. VM Management

- » Ensuring your infrastructure is secure requires **frequent updates** directly to your virtual machine.
- » Staying up-to-date requires a significant investment in ways to **identify the latest threats and patches** available in the market.
- » A SaaS provider **continuously performs these tasks on standardized VM images and third-parties** used in its software. Therefore, the time between **a breach** and the **resulting patch** is reduced.

5. Data Protection

- » The most important practice of all is the SaaS provider's methodology for **preventing a data breach**, primarily by using various methods for **data encryption both at rest and in transit**.
- » Best practice solutions **offer customers the option to control their encryption keys** so that cloud **operations staff cannot decrypt customer data**.
- » All this becomes more important with the stringent safeguards required **for personally identifiable information** (PII).

6. Governance and Incident Management

- » **Certain types of incidents must be captured, reported, and tracked to closure**, and there must be procedures in place for investigating any potential security breaches

Seven pillars of SaaS security

4. Scalability & Reliability

- » One of the biggest features of the cloud is the **ability to increase capacity of existing hardware or software** by adding **resources as and when needed**.
- » **Vertical scaling is limited** by only being able to get **as large as the size of the server**.
- » Horizontal scaling means the **ability to connect multiple hardware or software entities, such as servers**, so that they work as **a single logical unit**.
- » This kind of scale, however, **cannot be implemented** at a moment's notice, so a cloud computing vendor must build a considerable amount of horizontal redundancy into the infrastructure to ensure continuity of service.
- » A content delivery network or **content distribution network** (CDN) provides further **robustness through a geographically distributed network of proxy servers** and their data centers.
- » Finally, there must be a **disaster recovery (DR) plan** in place for **replicating data and services** in the event of a natural or human-induced regional disaster.

Security monitoring

- » Security monitoring is the automated process of collecting and analyzing indicators of potential security threats, then triaging these threats with appropriate action.
- » It involves collecting and analyzing information to detect suspicious behavior or unauthorized system changes on your network, defining which types of behavior should trigger alerts, and taking action on alerts as needed.
- » The type of the security monitoring is dependent on the applications, size of the network, and level of control needed.
- » The company providing the monitoring service scans every part of the system while looking for unwanted changes and vulnerabilities and can act on them either by contacting to the administrator of the system or dealing with them on the spot.

Security Architecture Design

- » A security **architecture framework** should be established with consideration of processes (**enterprise authentication and authorization, access control, confidentiality, integrity, non-repudiation, security management, etc.**),
- » **operational procedures, technology specifications, people and organizational management, and security program compliance and reporting.**

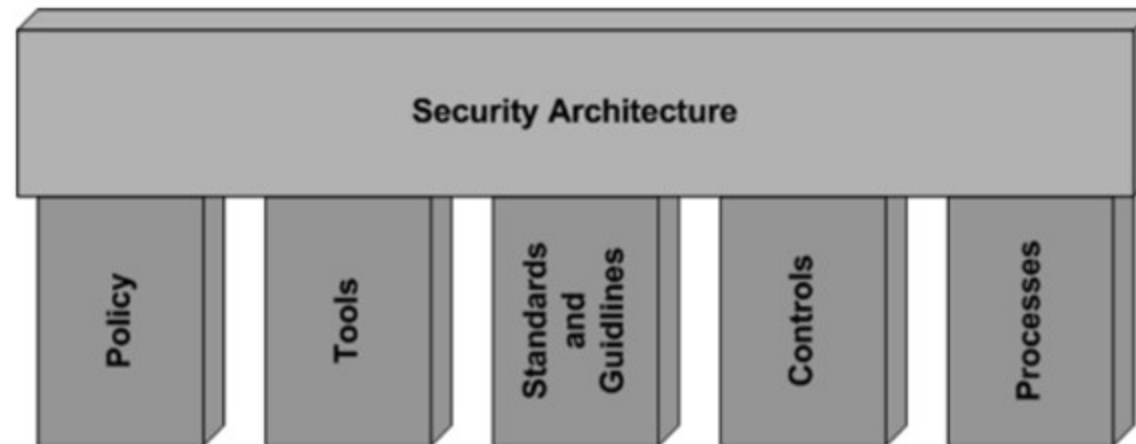


Fig. Security Architecture

Security Architecture Design

- » Technology and design methods should be included, as well as the security processes necessary to provide the following services across **all technology layers**:
 1. Authentication 2. Authorization
 3. Availability 4. Confidentiality
 5. Integrity 6. Accountability
 7. Privacy
- » The creation of a secure architecture **provides the engineers, data center operations personnel, and network operations personnel a common blueprint to design, build, and test the security of the applications and systems.**
- » **Design reviews of new changes can be better assessed against this architecture** to assure that they conform to the principles described in the architecture, allowing for more consistent and effective design reviews.

Application Security

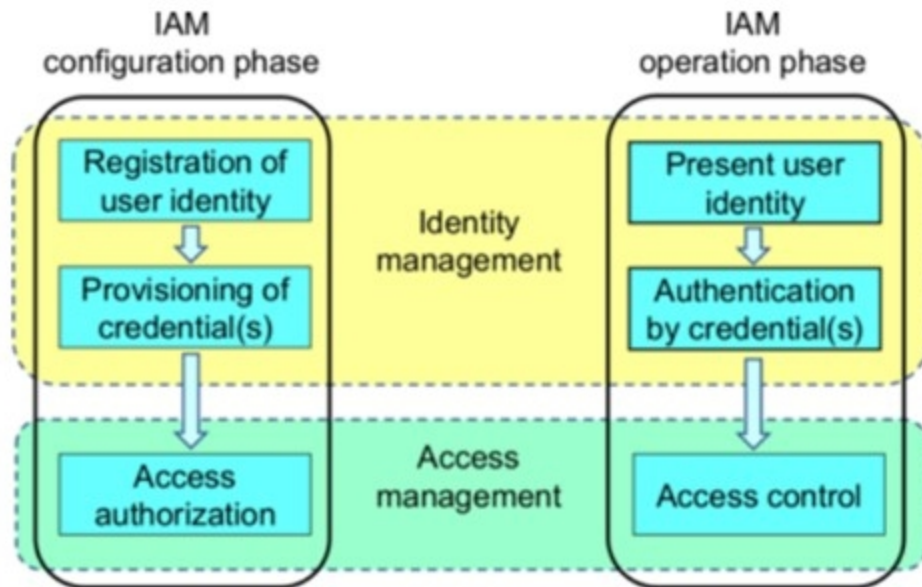
- » Application security is one of the critical success factors for a world-class SaaS company.
- » This is where the security features and requirements are defined and application security test results are reviewed.
- » Application security processes, secure coding guidelines, training, and testing scripts and tools are typically a collaborative effort between the security and the development teams.
- » Although product engineering will likely focus on the application layer, the security design of the application itself, and the infrastructure layers interacting with the application, the security team should provide the security requirements for the product development engineers to implement.
- » This should be a collaborative effort between the security and product development team.
- » External penetration testers are used for application source code reviews, and attack and penetration tests provide an objective review of the security of the application as well as assurance to customers that attack and penetration tests are performed regularly.
- » Fragmented and undefined collaboration on application security can result in lower quality design, coding efforts, and testing results.

Virtual Machine Security

- » In the cloud environment, physical servers are consolidated to multiple virtual machine instances on virtualized servers.
- » Not only can data center security teams replicate typical security controls for the data center at large to secure the virtual machines, they can also advise their customers on how to prepare these machines for migration to a cloud environment when appropriate.
- » Firewalls, intrusion detection and prevention, integrity monitoring, and log inspection can all be deployed as software on virtual machines to increase protection and maintain compliance integrity of servers and applications as virtual resources move from on-premises to public cloud environments.
- » By deploying this traditional line of defense to the virtual machine itself, you can enable critical applications and data to be moved to the cloud securely.
- » To facilitate the centralized management of a server firewall policy, the security software loaded onto a virtual machine should include a bidirectional stateful firewall that enables virtual machine isolation and location awareness, thereby enabling a tightened policy and the flexibility to move the virtual machine from on-premises to cloud resources.
- » Integrity monitoring and log inspection software must be applied at the virtual machine level.
- » This approach to virtual machine security has some advantages in that the security software can be put into a single software agent that provides for consistent control and management throughout the cloud while integrating seamlessly back into existing security infrastructure investments, providing economies of scale, deployment, and cost savings for both the service provider and the enterprise.

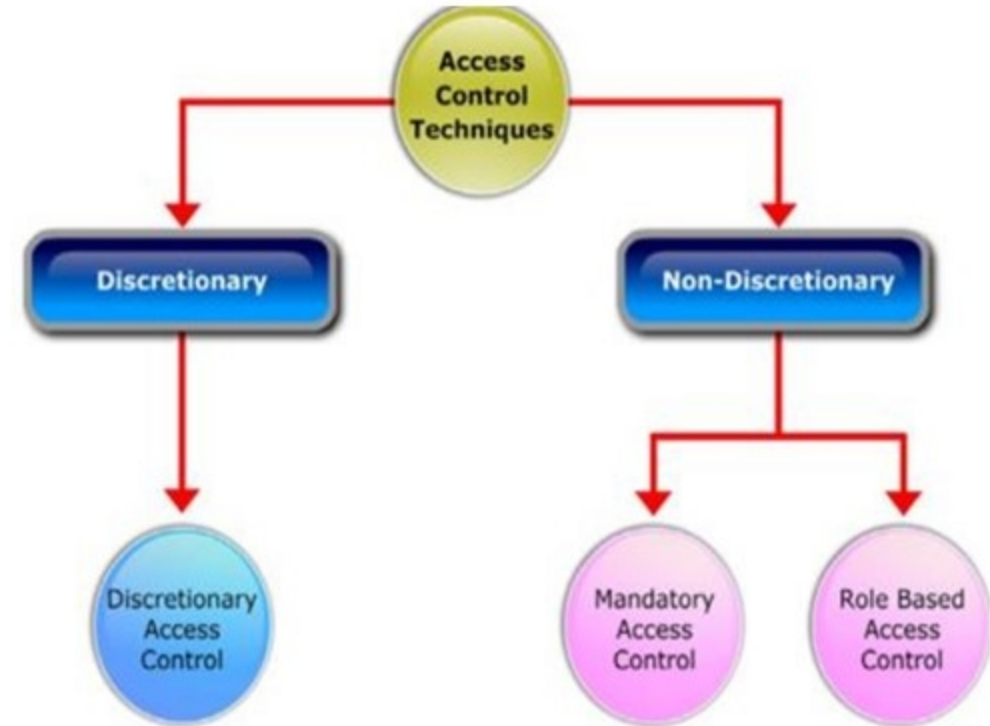
Identity management

- » Identity management is the process by which **user identities** are **defined and managed in an enterprise environment to keep systems and data secure**.
- » Primarily used to **authenticate a user on a system** and ascertain whether that user **is allowed or prohibited** access to a particular system.



Access control

- » Access control is a mechanism that **enables an authority to control access to areas and resources** in a given physical facility.
- » The three models are:
 - » 1. Discretionary Access Control (DAC)
 - » 2. Mandatory Access Control (MAC)
 - » 3. Role Based Access Control (RBAC)



Discretionary Access Control(DAC)

- » It is an **access policy determined by the owner of an object.**
- » The **owner decides who is allowed to access the object and what privileges they have.**
- » Two important concepts in DAC :
- » 1. **File and data ownership:** Every object in the system **has an owner and the access policy for an object is determined by its owner.**
- » 2. **Access rights and permissions:** These are the controls that an **owner can assign to other subjects for specific resources.**

Mandatory Access Control(MAC)

- » **An access policy that restricts the level of control that owners (subjects) have over the objects that they create.**
- » **Only the administrator** manages the access controls.
- » Used **in multilevel systems** that process **highly sensitive data**, such as classified government and military information.
- » In a MAC-based system, **all subjects and objects must have sensitivity** labels assigned to them.
- » A subject's sensitivity label **specifies its level of trust.**
- » An object's sensitivity label **specifies the level of trust required for access.**
- » In order to access a given object, **the subject must have a sensitivity level equal to or higher than the requested object.**

Role-based Access Control(RBAC)

- » It is an **access policy determined by the system, not the owner.**
- » It is used in **commercial applications and also in military systems, where multi-level security requirements** may also exist.
- » RBAC differs from DAC in that DAC allows **users to control access to their resources**, while in RBAC, **access is controlled at the system level, outside of the user's control.**
- » Although RBAC is non-discretionary, it can be **distinguished from MAC primarily** in the way permissions are handled. **MAC controls read and write permissions** based on a user's clearance level and additional labels.
- » It controls **collections of permissions** that may include **complex operations such as an e-commerce transaction**, or may be as simple as read or write.

